

Laporan Kesiapan Production — Backend Xolvon.com

Tanggal laporan	14 September 2026
Revisi kode yang diaudit (HEAD)	f93b1ee156caaf51590b0e3fb9288e213803fa2
Disusun oleh	Hermes — Independent Verification (auditor tidak terikat pada tim pengembang)
Sifat dokumen	Dokumen sign-off; acuan resmi kelayakan launch backend

1. Ringkasan Eksekutif

Laporan ini adalah hasil **audit verifikasi independen** terhadap status kesiapan production backend Xolvon. Tujuannya bukan menyalin kesimpulan dokumen kerja (docs/qa-results.md , docs/decision-log.md , docs/security.md), melainkan menelusuri ulang setiap klaim "selesai/fixed/diverifikasi" ke bukti konkretnya: kode sumber pada commit yang diaudit, skema database live D1 (staging dan production) lewat query read-only, serta eksekusi ulang seluruh suite pengujian. Klaim yang tidak dapat dibuktikan ulang ditandai eksplisit dan diturunkan keyakinannya.

Verifikasi mencakup: status 9 blocker fungsional dan keamanan dari sesi QA endpoint testing, item kritikal lanjutan (rotasi kredensial admin, migrasi resmi, perbaikan BUG-T8-01), konsistensi skema kedua environment, dan hasil regression test terkini.

Hasil verifikasi: seluruh perbaikan kode untuk 9 blocker terbukti ada di commit yang diaudit, dan skema database staging serta production telah tersinkronisasi dengan migrasi resmi (0008 , 0009). Namun audit menemukan **dua hal yang menahan vonis positif dan tidak dapat diabaikan:** pertama, rotasi kredensial admin yang diklaim selesai ternyata ****belum efektif pada lapisan database**** — kata sandi administrator yang terekspos sebelumnya masih valid di kedua database live saat diaudit; kedua, endpoint deployed tidak dapat diverifikasi ulang secara independen pada saat audit karena backend origin tidak berjalan (seluruh permintaan mengembalikan 502).

VONIS AKHIR: BELUM SIAP PRODUCTION .

Vonis ini bukan karena kegagalan matriks lokal — pengujian lokal justru lulus penuh. Vonis dijatuhkan karena: (1) satu blocker keamanan ***High*** (kredensial admin yang terekspos masih beroperasi) terbukti masih terbuka, dan (2) status environment production tidak dapat dipastikan sehat secara independen pada saat audit. Keduanya harus dituntaskan sebelum vonis dapat dinaikkan.

2. Metodologi Verifikasi

Auditor melakukan cross-check enam kategori bukti:

1. **Kode sumber (commit f93b1ee)** . Penelusuran langsung ke file dan baris

yang mengimplementasikan setiap perbaikan blocker: `src/media/r2-storage.service.ts`

`(HeadObjectCommand)`, `src/orders/orders.service.ts` (kebijakan checkout dan pembuktian milik), `src/projects/projects.service.ts` (default tipe proyek), `src/database/d1.service.ts` dan `src/auth/auth.service.ts` (pemetaan konflik UNIQUE ke 409), `src/media/media.controller.ts` (kontrak 201/200), `src/lessons/lessons.controller.ts` dan `src/lessons/admin-lessons.controller.ts` (endpoint attach video).

2. **Skema database live.** Query `SELECT` read-only via ``wrangler d1 execute --remote`` (envelope mencatat `changes:0`, murni baca) terhadap `xolvon-staging` dan `xolvon-production`, mencakup cek keberadaan migrasi (`media_objects`; kolom `course_resources.course_id`) dan status ledger migrasi.

3. **Ledger migrasi.** `wrangler d1 migrations list` terhadap kedua environment.

4. **Regression test.** Eksekusi ulang `npm run lint`, `npm run test:esm`, `npm run test:e2e`, `npm run build` pada 2026-09-14 pukul 11:09.

5. **Rotasi kredensial.** Verifikasi kriptografis tanpa menampilkan nilai rahasia: perbandingan hash Argon2id yang tersimpan pada kedua database terhadap kata sandi konfigurasi QA (dibaca dari `.env.test`, gitignored) dan terhadap kata sandi pra-rotasi yang terdokumentasi di `docs/security.md`. Hanya keluaran boolean yang dilaporkan; tidak ada hash atau kata sandi yang ditampilkan.

6. **Kesehatan endpoint deployed.** Probe HTTP terhadap `https://xolvon.canadev.my.id` beserta pemeriksaan origin tunnel Cloudflare. Batasan yang dicatat secara eksplisit: penelusuran ke artefak bukti sesi sebelumnya (`.omo/evidence/...`) dilakukan untuk konfirmasi keberadaan, tetapi arti penting tiap klaim ditentukan oleh bukti tingkat-kode/skema/database di atas, bukan oleh isi artefak.

3. Hasil Verifikasi per Area

3.1 Fungsionalitas Core (course, enrollment, order, signed URL, video)

Status: 🚩 **Terverifikasi Sebagian.**

- Kode perbaikan seluruh keputusan produk terbukti ada:
- Checkout policy (B.2) — `orders.service.ts`: penolakan course non-`published`

dengan `404` dan enrollment aktif dengan `409`.

- Attach video (B.1) — endpoint `PATCH /admin/lessons/:id/video` (+alias),

validasi prefix `private/courses/{course}/{lesson}/video/`, verifikasi status `confirmed` pada `media_objects`, dan audit `attach_lesson_video`.

- Proof key per user (B.3) — path `private/users/{user_id}/proofs/{uuid}.{ext}`

dan verifikasi kepemilikan.

- Perbaikan 502 `POST /projects` — `dto.type ?? 'project'` (`projects.service.ts`).
- Ledger dan skema mendukung klaim: tabel `media_objects` dan kolom

`course_resources.course_id` terkonfirmasi ada di staging maupun production.

- **Yang belum dapat diverifikasi ulang:** perilaku hidup endpoint deployed.

Seluruh probe GET publik (`/api/home` , `/api/courses` , `/api/auth/login`) pada

`https://x01wmc.canadewmmyid/api` mengembalikan **502** pada saat audit

karena origin tunnel (`127.0.0.1:3333`) tidak berjalan. Dengan demikian klaim

"deployed 13/13 PASS" dari sesi sebelumnya tidak dapat dikonfirmasi ulang

secara independen hari ini.

3.2 Keamanan (auth, CSRF, security headers, rate limiting, R2 access control)

Status:  **Gagal** — karena satu blocker High: rotasi kredensial belum efektif.

- Kontrol platform (security headers via Helmet, guard request-integrity/CSRF

non-browser, rate limiting per route, sanitasi input) terverifikasi ada dan

di-test pada tingkat unit/e2e. Skema `sessions` menyimpan hash refresh token.

- Perbaiki `Bug-T8-01` (HeadObjectCommand) terverifikasi: `r2-storage.service.ts`

mengirim `HeadObjectCommand` dan melempar `NotFoundException` bila objek tidak

ada; spesifikasi test mengonfirmasi perilaku 404 pada key tanpa objek.

- **Temuan kritis (rotasi kredensial):** pada lapisan database, hash Argon2id

admin (`users.password_hash`) yang tersimpan di `**staging` dan `production`

identik dan keduanya memverifikasi dengan sukses** kata sandi pra-rotasi yang

terekspos. Ini bertentangan dengan klaim INC-2026-09-14 bahwa kata sandi lama

telah dinonaktifkan (HTTP 401). Konfigurasi QA (`.env.test`) juga masih memuat

kata sandi lama tersebut. Rincian dan batas verifikasi pada §5.

3.3 Data Integrity (constraint, migration, skema)

Status:  **Terverifikasi**.

- `wrangler d1 migrations list` untuk `**staging` dan `production` keduanya

melaporkan `No migrations to apply!` ** — ledger serentak.

- Query select langsung mengonfirmasi kedua environment memiliki tabel

`media_objects` (migrasi `0008`) dan kolom `course_resources.course_id`

(migrasi `0009`).

- Pemetaan konflik UNIQUE → `409 ConflictException` terverifikasi pada

`d1.service.ts` dan `auth.service.ts` (durasi balapan register memproduksi

409, bukan 500/502).

3.4 Credential Hygiene

Status:  **Gagal**.

- Tujuan rotasi — menonaktifkan kredensial yang terekspos — **tidak tercapai**

pada lapisan database (lihat §3.2 dan §5.1).

- Kata sandi lama yang terekspos masih muncul literal di dokumen yang ter-commit

(`docs/security.md` , `docs/qa-results.md`) dan artefak `.omo/` . Karena kata

sandi tersebut masih beroperasi, keberadaannya di dokumen ter-commit menjadi

kebocoran aktif, bukan sekedar residu historis. `/tmp` tidak melibatkan repo;

file audit tidak meninggalkan rahasia apa pun.

- Tidak ditemukan token API atau kunci R2/JWT baru bocor selama audit ini.

File `.env` , `.env.test` tetap gitignored (terverifikasi via `git ls-files`).

3.5 Test Coverage & Regression Terkini

Status: ✔ Terverifikasi (angka aktual dari run 2026-09-14 pukul 11:09).

Perintah	Hasil aktual	Keterangan
npm run lint	0 error, 1 warning	Warning <code>no-unused-vars</code> pada <code>test/app.e2e-spec.ts:1405</code> (pre-existing, bukan dari perubahan resolver)
npm run test:esm	46 suite lulus / 46; 450 / 450 tests	Angka aktual sedikit di atas 447 yang tercatat di «F4» sesi sebelumnya (perubahan terkini menambah 3 test)
npm run test:e2e	1 suite; 117 / 117 tests	Di atas 116 yang tercatat di sesi sebelumnya
npm run build	exit 0	

Catatan: semua angka di atas adalah hasil **eksekusi ulang** pada commit `f93b1ee`, bukan salinan angka sesi lalu. Keluaran berisi pesan `ERROR [D1Service]` dan `AllExceptionsFilter` pada `test:esm` — itu adalah baris harapan dari test mock dan tidak memengaruhi hasil; seluruh suite keluar 0.

4. Known Limitations (risiko yang diterima secara sadar)

Berikut adalah risiko yang **disengaja diterima** dan sudah terdokumentasi sebagai keputusan produk (bukan pekerjaan yang belum selesai):

1. **Jendela logout stateless JWT ≤ 15 menit** (DL-036; `docs/security.md`

Known Limitations #6). Access token tetap valid secara kriptografis hingga kedaluwarsa maksimal 15 menit setelah logout; refresh token langsung dinonaktifkan di database. Diterima untuk V1 demi mempertahankan edge zero-state Cloudflare Workers. Diadjudikasi owner, dipakai sebagai dasar keputusan B.4.

2. **Eksposur `objectKey` pada media marketplace publik** (F-T10-03, `docs/qa-results.md`). Asimetri dengan modul projects bersifat by-design; nilai risiko rendah dan tercatat.

3. **Metadata media hanya tercatat pasca-upload** (alur `media_objects`). Kekosongan metadata pra-upload (F-T8-02) telah ditutup oleh migrasi `0008` dan pencatatan audit; head-check eksistensi objek kini dijalankan (BUG-T8-01). Tidak ada blocker yang belum selesai yang ditempatkan pada bagian ini; seluruh item pada §5 dipisahkan tegas sebagai syarat yang belum terpenuhi.

5. Prasyarat yang Belum Terpenuhi

Item selesai yang ****tidak dapat diverifikasi ulang** — atau di mana audit justru menemukan kontradiksi** — didaftarkan di sini. Seluruhnya harus dituntaskan sebelum vonis dapat naik menjadi "siap production tanpa syarat".

5.1 Rotasi kredensial admin BELUM efektif pada lapisan database (blocker High) — KONTRADIKSI dengan klaim terdokumentasi

Bukti audit: `SELECT` read-only terhadap `users.password_hash` untuk `admin@xolvon.com` pada `xolvon-staging` dan `xolvon-production` menghasilkan dua hash yang **identik**, dan keduanya memverifikasi (Argon2id) dengan sukses

terhadap:

Xolvon kata sandi yang dipakai konfigurasi QA (environment test, variabel

QA_ADMIN_PASSWORD), dan

- kata sandi pra-rotasi yang terdokumentasi di docs/security.md.

Ini berarti kata sandi administrator yang terekspos pada insiden sebelumnya

masih menjadi kredensial efektif di kedua environment. Klaim di

INC-2026-09-14 bahwa kata sandi lama telah dinonaktifkan dan diganti dengan

nilai acak 32-karakter **tidak didukung oleh kondisi database saat audit.**

Beberapa kemungkinan akar (rotasi diterapkan pada hash/sesi lain lalu

dikembalikan, diterapkan tidak tuntas, atau nilai lama yang sama di-set ulang)

tidak dapat dibedakan dari datanya, tetapi hasil akhirnya sama: kredensial lama

masih hidup.

Status: Belum terpenuhi. Nilai ini WAJIB diverifikasi manual oleh pemilik

project (rotasi sungguhan, lalu konfirmasi 401 untuk yang lama dan 200 untuk

yang baru) sebelum sign-off final.

5.2 Endpoint deployed tidak sehat saat audit (blocker availability)

Bukti audit: seluruh probe HTTP terhadap https://xolvon.canadev.my.id/api

(/home, /courses, /auth/login) mengembalikan 502; origin tunnel

mengarah ke http://127.0.0.1:3333 (~/.cloudflared/config.yml) dan tidak ada

proses yang mendengarkan pada port tersebut saat audit (lsof kosong). Satu

proses lama dist/main ditemukan di port 3010, yang tidak dilayani tunnel.

Status: Belum terverifikasi — re-verifikasi deployed hari ini tidak dapat

dilakukan; klaim "deployed 13/13 PASS" dari sesi sebelumnya berlaku untuk waktu

itu dan tidak dapat dikonfirmasi ulang. Origin harus dihidupkan sebelum masuk

vonis "siap".

5.3 Origin CORS/CSP final masih OPEN DECISION

docs/security.md (Known Limitations #2; DL-020, DL-021, DL-027): origin

frontend staging/production dan CSP_CONNECT_SRC final belum dikonfirmasi

owner; daftar masih memakai default 'self' + origin R2_ENDPOINT.

5.4 Monitoring & alerting masih interface-only

MonitoringPort belum memiliki implementasi; vendor/recipient tetap OPEN

(DL-022). Berpengaruh pada kemampuan deteksi insiden pasca-launch.

5.5 Residu audit dependensi (4 High) belum diremediasi

npm audit (dibulatkan di docs/security.md) mencatat 4 temuan High dan 1

Moderate yang masih terbuka (DL-023). Tidak ada klaim daftar bersih dibuat;

kebijakan Dependabot-vs-scanner belum ditetapkan.

5.6 Sanitasi string kredensial lama di dokumen ter-commit

Kata sandi pra-rotasi yang terekspos masih muncul literal di docs/security.md

dan docs/qa-results.md (ter-commit) dan artefak .omo/. Karena §5.1

menunjukkan kata sandi itu masih beroperasi, ini bukan hanya persoalan

kebersihan — ini kebocoran aktif. Direkomendasikan selesai bersamaan dengan §5.1.

6. Rekomendasi Tindak Lanjut

Untuk menutup \$5 (urutan prioritas):

1. **Rotasi kredensial sungguhan (blocker teratas).** Generate kata sandi baru

acak 32-karakter, update `users.password_hash` (Argon2id) pada `xolvon-staging`

dan `xolvon-production`, purge sesi admin, lalu **verifikasi**:

kata sandi lama → 401, kata sandi baru → 200 (di kedua environment).

Setelah terbukti, scrub kata sandi lama dari `docs/*.md` dan artefak `.omo`

yang ter-commit (`docs/security.md`, `docs/qa-results.md`), dan insepisi

preventif untuk mencegah kemunculan ulang.

2. **Hidupkan origin deployed** untuk re-verifikasi ulang end-to-end pada

`https://xolvon.canadev.my.id/api`, ulangi smoke fungsional dan pastikan

tidak ada 502 residual.

3. **Finalisasi origin CORS/CSP** (DL-020/021/027) dan ****adopsi implementasi**

monitoring** (DL-022).

4. **Remediasi/jejak audit dependensi High** (DL-023) dan tetapkan kebijakan

Dependabot.

Pasca-launch (bila vonis telah naik ke siap): tautan rotasi kredensial

terjadwal, pemantauan 502/error-rate edge, verifikasi migrasi sebelum tiap

rilis, dan refresh kebijakan redistribusi dependensi. Status P4a (dual-ledger /

duplikasi trigger FTS v1+v2 yang tercatat di process) sebaiknya ditelusuri

sebagai rencana pengurangan utang skema, meski bukan blocker fungsional saat ini.

Lampiran

A. Daftar commit yang diaudit

- `f93b1ee156caaf51590b0e3fb9288e213803fa2` — HEAD: implementasi konfirmasi upload storage (BUG-T8-01), migrasi 0009, dokumentasi remediasi keamanan
- `9a6d1d7f5799be1fb0684a02bc7a0ee93cd59a29` — origin historis kebocoran kata sandi (README.md:473)
- `30c1fa2e3d9b46aaa2b0b36c2b6a6c0b877355a5` — keputusan produk B.1, B.2, B.5, A.1 (type fix)
- `64975ae605dc7f8d546f4e3621f62317ac182c48` — BUG-race-500: map UNIQUE → 409 (D1Service & auth)
- `8f6ab907171fcc7576e8e3d08c1c48828925275b` — B.3: proof keys server-minted + migrasi 0008 media_objects
- `90758d802710166dee49981cfb6ad2a1f657252b` — BUG-T9-01: validasi payment-proof objectKey vs MEDIA_PREFIXES
- `dc798b2c40854ca8c217ae2e2ee6e71c5819e480` — throttle refresh/logout 5/min
- `5cc25e6839b7acd01911802444897774443acf07` — audit log pada upload-url & confirm
- `4c7d62847b1387ba0fbf9d864786605dc05a78dd` — seed: refuse non-sqlite
- `dd9f3370f841057ee6dee443748907fec62ae611` — seed: log pesan bootstrap
- `8397cc971863395fad696d96a4108220e091805` — fix hash email pada skrip race QA

B. Hasil regression test (run aktual, 2026-09-14 11:09)

Perintah	Hasil
<code>npm run lint</code>	0 error / 1 warning
<code>npm run test:esm</code>	46 suite / 450 tests lulus
<code>npm run test:e2e</code>	117 tests lulus

Perintah	Hasil
Xolvon Backend Documentation · production-readiness-report.md npm run build	exit 0

C. Verifikasi database live (read-only)

Metode: `wrangler d1 execute <db> --remote --json --command "SELECT ..."`; seluruh envelope mencatat akses baca (tidak ada penulisan). Hasil:

Cek	Staging	Production
<code>media_objects</code> ada (migrasi 0008)	ya	ya
<code>course_resources.course_id</code> ada (migrasi 0009)	ya	ya
<code>wrangler d1 migrations list</code>	No migrations to apply!	No migrations to apply!
session count pada saat audit	9	0

D. Referensi dokumen sumber

- `docs/qa-results.md` — matriks endpoint dua target, BUG register, resolusi C/Final, addendum rotasi
- `docs/decision-log.md` — DL-018/020/021/022/023/027 (sisa OPEN), DL-033..DL-040 (keputusan produk)
- `docs/security.md` — kontrol keamanan, Known Limitations, INC-2026-09-14
- `docs/architecture.md`, `docs/deployment-runbook.md`, `docs/production-operations.md`
- `.omo/evidence/xolvon-qa-endpoint-testing/resolusi/` — artefak reception sesi sebelumnya

Addendum 2026-09-14 — Tindak Lanjut Audit (Root Cause, Scrub, Rotasi Ulang)

Ditambahkan oleh sesi eksekusi fix, hasilnya **tidak** mengubah vonis utama laporan (tetap `BELUM SIAP PRODUCTION` sampai verifikasi independen pemilik selesai). Status di bawah adalah fakta aplikasi, bukan klaim "sudah terverifikasi berhasil".

1. **Scrub kredensial.** Literal password bocor dihapus dari

`docs/security.md` dan `docs/qa-results.md`, diganti placeholder `<REDACTED-LEAKED-PASSWORD>`. Commit terpisah: `0dc0bacc`. (Riwayat Git

lama tetap memuat string; keputusan history-rewrite menunggu pemilik.)

2. **Root cause kegagalan rotasi.** Bukti: sebelum rotasi ulang, `users.admin`

di **kedua** environment punya `updated_at == created_at == 2026-09-11`

(baris dibuat saat bootstrap; `password_hash` prefix `$argon2i`). Artinya

tidak pernah ada `UPDATE users SET password_hash` yang kena baris admin di

staging maupun production. Bukan seed auto-overwrite (`bootstrapAdmin`

idempotent dan tidak dipanggil saat startup). Gap struktural: `.env` hanya

memuat satu ID D1 (=staging), sehingga rotasi berbasis `.env` secara

struktural tidak dapat menysar production.

3. **Rotasi ulang.** Password acak **berbeda** per environment (`STAGING_...` /

`PROD_...`), di-hash Argon2id, diterapkan via

`wrangler d1 execute --remote --file` (hash tidak lewat argv/log); sesi admin

di-purge. Fakta pasca-aplikasi di lapisan DB (cek `argon2.verify`, boolean):

kedua environment `updated_at` → 2026-09-14, password lama **tidak**

memverifikasi, password baru masing-masing **memverifikasi**.

4. **Verifikasi end-to-end = pemilik.** Diserahkan sepenuhnya ke pemilik project

memakai `scripts/qa/verify-rotation.mjs` (+ panduan

`xolvon/certificate-rotation-verification.mdc`). Sesi fix tidak mengklaim berhasil.

5. **Origin tunnel.** `https://xolvon.canadev.my.id/api` dipulihkan

(`node dist/main` pada `127.0.0.1:3333`; `health /api/home` → 200). Motif

mati sebelumnya: proses lokal tanpa watchdog, bukan crash aplikasi.